SEGURANÇA INFORMÁTICA

- Teoria da Informação
- Fundamentos de segurança informática
- Conceitos
- Hackers
- Ethical hacking
- Classificação dos activos
- Classificação das vulnerabilidades
- Attackers
- Principais alvos dos hackers
- Guerra da informação
- Testes de penetração
- Metodologia de teste de segurança

Nanikafuako André, MSC

Adilson José da Silva Silvério

---

1. Introdução

Actualmente vivemos numa sociedade cada vez mais complexa e que apresenta grandes desafios quer do ponto de vista social e tecnológico. Neste sentido tem surgido muitos projectos /ideias desenvolvidos por organizações ou de forma individual, no sentido de elevar o bem-estar da humanidade (segurança, paz, felicidade, outros). Neste sentido tem se gerado um conjunto de conhecimento em torno de todo estes processos, fazendo com que cada vez mais as organizações prestem mais atenção nos mecanismos de proteção das informações manipuladas e produzidas.

O conceito de segurança é sem dúvida o conceito "mais ambíguo e perturbador relativamente ao edifício político-estratégico" (Borges, 2010, p. 8). Ao longo da história, este conceito tem tomado diversas definições consoante a época, pode-se dizer que vai do individuo (em si) até à sociedade de forma a contextualizar-se no meio ambiente em que está inserido, ou seja, a proteção dos cidadãos e da nação.

Segundo Sequeira (2004), este conceito como referido é um conceito complexo. Na tentativa de chegar a uma definição mais concreta, existem três objectivos que se encontram sempre assentes nestas definições:

1) Garantir os direitos do cidadão proporcionados pelas normas jurídicas, bem como pelas autoridades que os editam e aplicam;
2) Salvaguardar a ordem constitucional democrática contra perturbações graves de origem interna;
3) Preservar a coletividade contra agressões e ameaças externas.

A informação é, segundo a norma NBR ISO/IEC 27002 ABNT (2005), um activo importante para os negócios. Por atribuir valor à empresa, a informação precisa receber a proteção adequada. Para oferecer a proteção adequada, existe a segurança da informação, ou seja, uma forma de proteger informações de diversos tipos de ameaças. Essa proteção influencia no campo estratégico das empresas, contribuindo para a continuidade dos negócios, aumento das oportunidades, minimização de riscos e maximização do ROI (Retorno sobre os investimentos)

Na definição de Campos (2007), a segurança da informação existe com o propósito de garantir a confidencialidade, integridade e disponibilidade das informações de uma empresa. Já para a norma ABNT NBR ISO/IEC 27002 (2005), é adicionado o objectivo de garantir a autenticidade. Os princípios básicos da segurança da informação conforme a norma são:

- **Autenticidade:** este princípio prega a garantia da veracidade da fonte das informações. É preciso garantir que a informação que é trafegada tenha um proprietário e que este proprietário não foi alterado;
- **Confidencialidade:** ligado à garantia de que a informação não é acedida por alguém não autorizado, tanto internamente quanto externamente à organização. A informação deve ser protegida contra cópias e distribuições não autorizadas, garantindo que a informação é confidencial e somente pessoas autorizadas possuem acesso a ela;
- **Disponibilidade:** também conhecido como continuidade do serviço, é a garantia de que as informações estão disponíveis às pessoas autorizadas, sempre que elas necessitarem;
- **Integridade:** consiste na fidedignidade da informação. A informação trafegada precisa ser original, não podendo ter nenhum dado alterado, acrescentado ou removido sem a devida autorização da pessoa responsável por ela. Basicamente a informação não pode sofrer nenhum tipo de violação.

Tabela 1 - Risco e sua proteção pela implementação do CIA

CIA	**Risco**	**Controlo**
Confidencialidade	Perda de privacidade. Acesso não autorizado à informação. Roubo de identidade	Criptografia. Autenticação. Controle de acesso.
Integridade	As informações não são mais confiáveis ou precisas. Fraude.	Criador/Verificador. Garantia da Qualidade. Registros de auditoria (logs)
Disponibilidade	Interrupção de negócios. Perda de confiança do cliente. Perda de receita.	Continuidade do negócio. Planos e teste. Armazenamento de backup. Capacidade suficiente.

O que é um sistema seguro? A resposta depende de que nível de segurança se precisa. Em termos de segurança da informação, uma empresa que lida com segredos industriais, militares ou dados bancários tem demandas distintas em relação a uma pequena empresa de prestação de serviços. Cada organização possui diferentes necessidades de segurança no armazenamento e na comunicação da informação em meio eletrônico.

2. Conceitos

Segundo a lei 7/17 de 16 de Fevereiro de 2017 – Lei de proteção das redes e sistemas informáticos, define os seguintes elementos:

- **Acesso condicional** – a sujeição do acesso de um serviço a uma assinatura ou qualquer outra forma de autorização previa individual;

- **Assinante** – pessoa singular ou colectiva que é parte num contrato de um operador de comunicações eletrónicas acessíveis ao publico;
- **CERT** – Centro de Estudos, Respostas e Tratamento de incidentes informáticos;
- **Ciber** – é um adjectivo utilizado para descrever ou representar a realidade ou espaço virtual baseado em computadores/tecnologias de informação;
- **Ciber-ataque** – ataque efetuado geralmente através da internet, no qual são violados sistemas informáticos, com objectivos de espiar, provocar danos e roubar dados;
- **Ciberespaço** – o conjunto de sistemas tecnológicos e infra-estruturas de redes telemáticas, bem como o conjunto de informações e redes da internet;
- **Cibercrime** – o crime cometido com o recurso aos sistemas electrónicos e as novas tecnologias de informação e comunicação;
- **Cibersegurança** – a segurança relacionada com o ciberespaço; ou ainda segundo Kasperky (sd.) a ciber segurança é a pratica de defender computadores, servidores, dispositivos moveis, sistemas electrónicos, redes e dados contra ataques maliciosos. Tambem é conhecido com segurança da tecnologia de informação ou segurança da informação electrónica. O termo se aplica a vários contextos, dos negócios a computação movel, e pode ser dividido em algumas categorias como: redes, aplicações web móvel e outros.
- **Codigo de acesso** – dados ou senhas que permite aceder, no todo ou em parte e sob forma inteligível, à um sistema de informação;
- **Codigo de identificação do utilizador "User ID"** – o código único atribuído as pessoas, quando estas se tornam assinantes ou se registam num serviço de acesso a internet ou num serviço de comunicação pela internet;
- **Dados de localização** – quaisquer dados tratados num sistema de informação que indiquem a posição geográfica do equipamento terminal ou de um utilizador de um serviço prestado através de um sistema de informação;
- **Dados de tráfego** – qualquer dado tratado para efeito do envio de uma comunicação, através de um sistema de informação;
- **Dados informáticos** – quaisquer dados susceptiveis de processamento por um sistema informático;
- **Roubo informático** – qualquer apropriação indevida de uma rede, sistema informático, base de dados, equipamento informático, programa informático, usando a violência, ameaça, acesso ilegítimo com vista a estructuração incorreta de programa ou sistema informático;

- **Sociedade de informação** – sociedade em que as principais actividades estão integradas pelas novas tecnologias da informação e comunicação aonde a informação circula em rede electrónica;
- **Sistema informático** – qualquer dispositivo ou conjunto de dispositivo que procedem ao armazenamento, tratamento, recuperação ou transmissão de dados informáticos em execução de um programa de computador.
- **Incidentes informáticos** – qualquer evento real ou suspeito relacionado com a segurança de sistema informático ou rede;
- **Intercepção de comunicação** – acto destinado a captar dados contidos ou transmitidos através de um sistema de informação mediante a recurso a dispositivo.

Asset "Activo" – é o artigo ou item que deve ser protegido em uma organização, pode ser pessoa, objecto, informações/dados que possuem um determinado valor para organização;

Vulnerabilidade – é o ponto fraco de um *asset* que de alguma forma pode ser explorado.

Threats "Ameaças" – são um conjunto de situações ou tentativas que um *asset* pode sofrer e que podem resultar em acesso não autorizado, comprometer, destruir ou danificar o *asset*.

Risk "Risco" – é o potencial acesso não autorizado, comprometimento, destruição dano de um *asset*.

Countermeasure "Medidas de segurança" – são as acções, dispositivos ou processos definidos para proteger um *asset* contra as *threats*.

Hack Value – refere-se a um valor que denota atratividade, interesse, ou algo que vale apena. O valor descreve o nível de atração dos alvos para os hackers.

Zero-Day – refere-se a ameaças e vulnerabilidades que podem ser utilizadas para explorar a vítima, antes que o desenvolvedor identifique, resolva e libere qualquer patch pra esta vulnerabilidade. "Vulnerabilidade nunca antes explorada ou identificada."

Daisy Chaining – é um processo sequencia de várias tentativas de hacking ou ataque para obter acesso a rede ou sistemas, uma a pós a outra, usando as mesmas informações e as informações obtidas na tentativa anterior.

Exploit – são programas utilizados para explorar uma determinada vulnerabilidade.

Doxing – refere-se a à publicação de informações ou um conjunto de informações associados a um individuo ou organização. Estas informações são coletadas a partir de banco de dados disponíveis publicamente em redes sociais, engenharia social e hacking.

Payload – carga útil, ou seja, o produto “informação” real a ser transmitido, é uma secção ou parte de um código malicioso e que causa actividades e acções potencialmente destrutiva ou prejudiciais ao sistema alvo, como exploração, abertura da backdoor e hiajacking, worms, virus.

Bot – são softwares utilizados pra controlar um alvo remotamente e executar tarefas predefinidas. E capaz de executar scripts automatizados pela internet. São também conhecidos Internet bot ou Web robot, esses bot podem ser utilizados para fins sociais como finalidade comercial, finalidade maliciosa, vírus, worms, bonets ataques DDos. É um rastreador web, muitas vezes chamados de *spider*, *spiderbot* ou ainda de *crawler*, ou ainda robô da internet, que tem a função de indexar páginas de World Wide Web.

Ping sweep – é o processo de escaneamento da rede, no sentido de encontrar os dispositivos que fazem parte da rede.

Reverse lookup – permite localizar domínios pertencentes a uma determinada organização

Reverse whois – permite localizar os registos A associados a um endereço IP.

Deep web – é a parte da internet oculta, composta por um conjunto de servidores e serviços que não são alcançados utilizando ferramentas normais.

Dark web – é uma parte pequena da deep web. Composta por um conjunto de darknets como: frient-to-friend, peer-to-peer, freenet, I2P, Tor, Riffle.

3. Hackers

O individuo dotado de conhecimento, técnica e perícias em áreas relacionadas com segurança, rede e programação. Podendo utilizar estes conhecimentos para o bem ou mal.

O termo "Hacking" em segurança da informação refere-se à exploração das vulnerabilidades em um sistema, comprometendo a segurança para obter comando e controle não autorizados sobre os recursos do sistema. O objetivo do hacking pode incluir modificação de recursos do sistema, interrupção de recursos e serviços para atingir objetivos. Também pode ser usado para roubar informações para qualquer uso,

como enviá-las a concorrentes, órgãos reguladores ou divulgar informações confidenciais.

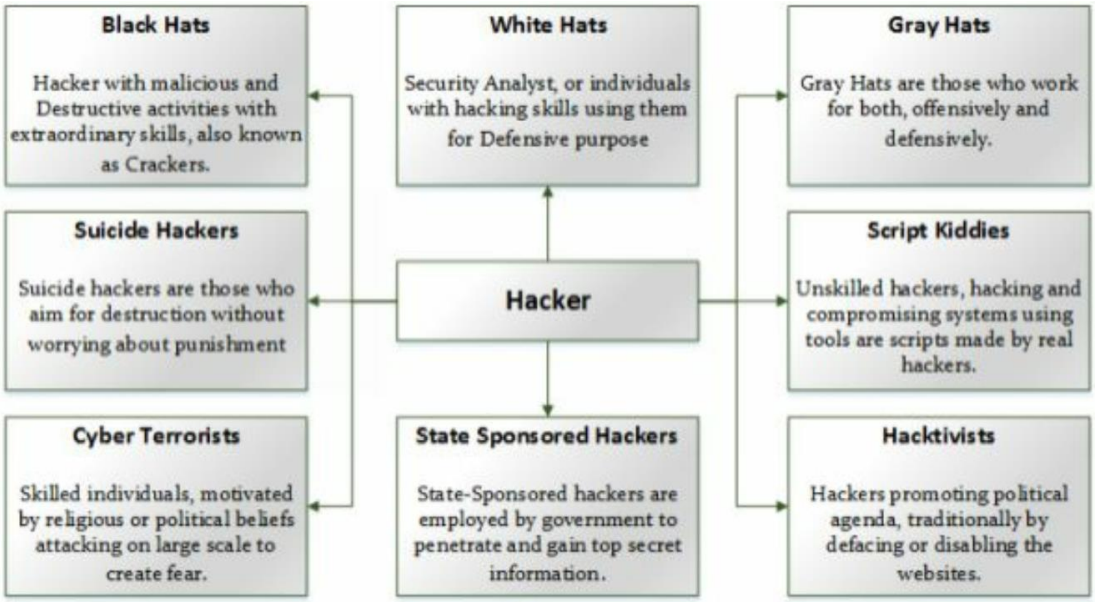

Figura 1 - Tipos de hackers

3.1. Fases de hacking

A seguir estão as cinco fases de hacking:

1. Reconhecimento;
2. Digitalização;
3. Ganhando acesso;
4. Mantendo o acesso;
5. Limpando trilhas ou rastros Cobertura de pistas ou eliminar rastros.

Reconhecimento "Reconnaissance"

O reconhecimento é uma fase inicial de preparação para o invasor se preparar para um ataque, reunindo as informações sobre o alvo antes de iniciar um ataque usando diferentes ferramentas e técnicas. A coleta de informações sobre o alvo torna mais fácil para um invasor, mesmo em grande escala. Da mesma forma, em larga escala, ajuda a identificar o alcance alvo.

No **Reconhecimento Passivo**, o hacker está adquirindo as informações sobre o alvo sem interagir diretamente com o alvo. Um exemplo de reconhecimento passivo é a mídia pública ou social que busca obter informações sobre o alvo.

O **Reconhecimento Activo** está obtendo informações adquirindo o alvo diretamente. Exemplos de reconhecimento ativo são por meio de chamadas, e-mails, help desk ou departamentos técnicos.

Digitalização “Scanning”

A fase de varredura é uma fase de pré-ataque. Nesta fase, o invasor varre a rede pelas informações adquiridas durante a fase inicial de reconhecimento.

As ferramentas de digitalização incluem Discador, Scanners, como scanners de porta, mapeadores de rede, ferramentas de cliente, como ping, bem como scanner de vulnerabilidades. Durante a fase de varredura, o invasor finalmente busca as informações das portas, incluindo status da porta, informações do sistema operacional, tipo de dispositivo, máquinas ativas e outras informações, dependendo da varredura.

Ganhando acesso “Gaining Access”

A fase de obtenção de acesso do hacking é o ponto em que o hacker obtém o controle sobre um sistema operacional, aplicativo ou rede de computadores. O controle obtido pelo invasor define o nível de acesso, como nível de sistema operacional, nível de aplicativo ou acesso em nível de rede. As técnicas incluem quebra de senha, negação de serviço, sequestro de sessão ou estouro de buffer e outras são usadas para obter acesso não autorizado. Após acessar o sistema; o invasor escala os privilégios para obter controle completo sobre os serviços e processos e comprometer os sistemas intermediários conectados.

Mantendo o Acesso / Escalonamento de Privilégios “Maintaining Access / Escalation of Privileges”

A fase de manutenção de acesso é o ponto em que um invasor está tentando manter o acesso, a propriedade e o controle sobre os sistemas comprometidos. Da mesma forma, o invasor impede que o proprietário seja de propriedade de qualquer outro hacker. Eles usam Backdoors, Rootkits ou Trojans para manter sua propriedade. Nesta fase, um invasor pode roubar informações fazendo upload das informações para o servidor remoto, baixando qualquer arquivo no sistema residente e manipulando os dados e a configuração. Para comprometer outros sistemas, o invasor usa esse sistema comprometido para lançar ataques.

Limpando trilhas “Clearing Tracks”

Um atacante deve esconder sua identidade cobrindo os rastros. Os rastros de cobertura são as atividades que são realizadas para ocultar as atividades maliciosas.

Cobrir o rastro é mais necessário para um invasor cumprir suas intenções, continuando o acesso ao sistema comprometido, permanecer indetectável e obter o que deseja, permanecer despercebido e limpar todas as evidências que indiquem sua identidade.

Para manipular a identidade e a evidência, o invasor substitui o sistema, o aplicativo e outros *logs* relacionados para evitar suspeitas.

4. Hacking Ético "Ethical Hacking"

Hacking ético e teste de penetração são termos comuns, populares no ambiente de segurança da informação há muito tempo. O aumento de crimes cibernéticos e hackers cria um grande desafio para especialistas e analistas de segurança e regulamentações na última década. É uma guerra popular entre hackers e profissionais de segurança.

Os desafios fundamentais para esses especialistas em segurança são encontrar pontos fracos e deficiências em sistemas, aplicativos e softwares em execução e futuros e resolvê-los de forma proativa. É menos dispendioso investigar proactivamente antes de um ataque em vez de investigar depois de cair em um ataque ou enquanto lida com um ataque. Para o aspecto de segurança, prevenção e proteção, as organizações têm suas equipes de testes de penetração internamente, bem como especialistas profissionais externos contratados quando e se forem necessários, dependendo da gravidade e do escopo do ataque.

Por que o Ethical Hacking "Hacker Ético" é necessário?

O aumento de ativações maliciosas, crimes cibernéticos e aparecimento de diferentes formas de ataques avançados exigem a necessidade de testadores de penetração que penetrem na segurança do sistema e das redes para determinar, preparar e tomar medidas de precaução e remediação contra esses ataques agressivos.

Esses ataques agressivos e avançados incluem:

- Ataques de negação de serviço;
- Manipulação de dados;
- Roubo de identidade;
- Vandalismo;
- Roubo de cartão de crédito;
- Pirataria;
- Roubo de Serviços.

Habilidades de um Hacker Ético

Um hacker habilidoso e ético possui um conjunto de habilidades técnicas e não técnicas.

Habilidades técnicas:

- O Ethical Hacker tem um conhecimento profundo de quase todos os sistemas operacionais, incluindo todos os sistemas operacionais populares e amplamente usados, como Windows, Linux, Unix e Macintosh.
- Esses hackers éticos são hábeis em redes, básicos e detalhados
- conceitos, tecnologias e explorando capacidades de hardware e
- Programas.
- Os hackers éticos devem ter um forte comando sobre as áreas de segurança, questões relacionadas e domínios técnicos.
- Eles devem ter conhecimento detalhado de ataques mais antigos, avançados e sofisticados.

Habilidades não técnicas:

- Capacidade de aprendizagem;
- Habilidades de resolução de problemas;
- Habilidades de comunicação;
- Comprometido com as políticas de segurança;
- Conhecimento das leis, normas e regulamentos.

Fases do Hacking Ético:

1. Reconhecimento;
2. Digitalização;
3. Enumeração;
4. Invasão do sistema;
5. Escalonamento de privilégios;
6. Cobertura de pistas ou eliminar rastros.

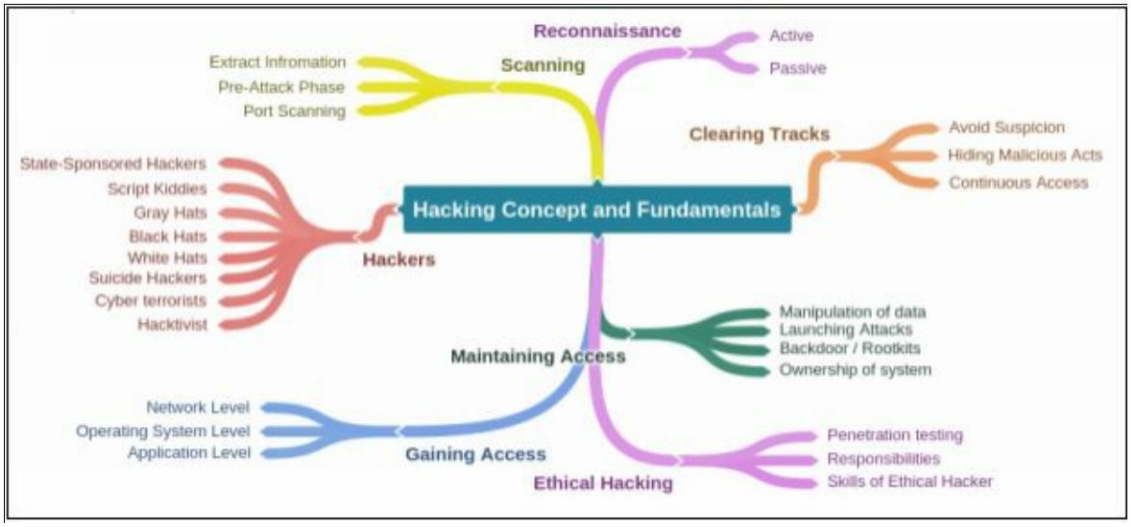

Figura 2 - Resumo do hacker ético

5. Calssificação dos activos

- Governamental: não classificado, sensível, sensível mas não classificado, confidencial, secreto e top secreto.
- Privado: público, sensível, privado e confidencial.
- Por critério: valor, ano, custo e tempo de vida útil.

Podemos também classificar os activos quanto a coloração dos documentos ou informações, respeitando quatro níveis definidos no *Traffic Light Protocol (TLP).*

O TLP foi criado para facilitar um maior compartilhamento de informações. TLP é um conjunto de designações usadas para garantir que informações confidenciais sejam compartilhadas com o público apropriado. Ele emprega quatro cores para indicar os limites de compartilhamento esperados a serem aplicados pelo(s) destinatário(s).

Tabela 2 - TLP

Cor	**Quando deve ser utilizado?**	**Como pode ser partilhado?**
Vermelho/Red	As fontes podem usar TLP: RED quando as informações não podem ser efectivamente utilizadas por outras partes e podem levar a impactos na privacidade, reputação ou operações de uma parte se forem mal utilizadas.	Os destinatários não podem compartilhar informações TLP: RED com terceiros fora da troca, reunião ou conversa específica em que foram originalmente divulgadas.
Âmbar/Amber	As fontes podem usar TLP: AMBER quando as informações requerem apoio para serem efectivamente atuadas, mas acarretam riscos à privacidade, à reputação ou às operações se forem compartilhadas fora das organizações envolvidas.	Os destinatários só podem compartilhar informações TLP: AMBER com membros de sua própria organização que precisam saber, e apenas na medida necessária para agir com base nessas informações.
Verde/Green	As fontes podem usar TLP: GREEN quando a informação for útil para a conscientização de todas as organizações participantes, bem como de pares dentro da comunidade ou setor mais amplo.	Os destinatários podem partilhar informações TLP: GREEN com pares e organizações parceiras dentro do seu setor ou comunidade, mas não através de canais acessíveis ao público.
Branco/White	As fontes podem usar TLP: BRANCO quando a informação apresenta risco mínimo ou nenhum	TLP: As informações BRANCAS podem ser distribuídas sem restrições, sujeitas a

	risco previsível de uso indevido, de acordo com as regras e procedimentos aplicáveis para divulgação pública.	controles de direitos autorais.

6. Classificação das vulnerabilidades

Podemos classificar as vulnerabilidades de um sistema tendo em consideração os seguintes elementos:

- Políticas fracas;
- Erros de desenho;
- Protocolos vulneráveis;
- Factor humano;
- Vulnerabilidade no software;
- Vulnerabilidade no hardware;
- Acesso físico aos recursos da rede.

Tipos de avaliação de vulnerabilidade

- Avaliação activa;
- Avaliação passiva;
- Avaliação baseada no host;
- Avaliação interna;
- Avaliação externa;
- Avaliação da rede;
- Avaliação da rede sem fio;
- Avaliação do aplicativo.

7. Attackers

- Terroristas;
- Agências governamentais;
- Estado/Nação;
- Hackers;
- Funcionário descontente;
- Concorrência.

8. Principais alvos dos hackers

- Financeiro;
- Geopolítica;
- Distúrbio.

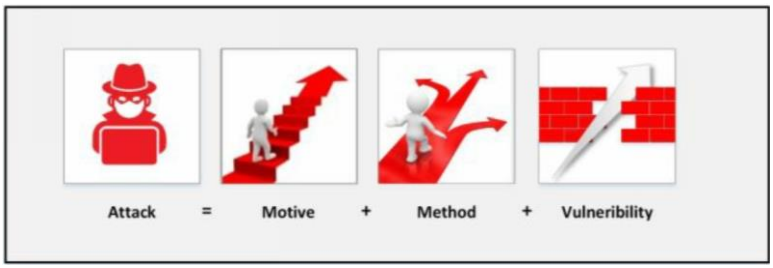

Figura 3 - Ataque de segurança da informação

9. Guerra de Informação

A guerra de informação é um conceito de guerra, utilizado para o máximo de informação. O termo "Guerra da Informação" descreve o uso da tecnologia da informação e comunicação (TIC). A principal razão ou foco desta guerra de informação é obter uma vantagem competitiva sobre o adversário, oponente ou inimigo. A seguir está a classificação da guerra de informação em duas classes:

Guerra de Informação Defensiva

O termo guerra de informação defensiva é usado para se referir a todas as ações defensivas que são tomadas para se defender de ataques para roubar informações e processos baseados em informações. As áreas de armazenamento de informações defensivas são:

- Prevenção;
- Dissuasão;
- Indicação e aviso;
- Detenção;
- Preparação para emergências;
- Resposta.

Guerra de Informação Ofensiva

O termo ofensivo está associado aos militares. A guerra ofensiva é uma operação agressiva que é realizada contra os inimigos dinamicamente, em vez de esperar que os atacantes lancem um ataque. Acessar seu território para ganhar em vez de perder território é o conceito fundamental da guerra ofensiva. A principal vantagem da guerra ofensiva é identificar o oponente, as estratégias do oponente e outras informações. A guerra de informação ofensiva impede ou modifica o uso da informação considerando integridade, disponibilidade e confidencialidade.

10. Teste de penetração

No ambiente de Ethical Hacking, o termo mais comum usado com frequência é "pentester". Pentesters são o testador de penetração que tem permissão para hackear

um sistema pelo proprietário. Teste de penetração é o processo de hackear um sistema com a permissão do proprietário desse sistema, para avaliar segurança, valor de hack, alvo de avaliação (TOE), ataques, explorações, vulnerabilidade de dia zero e outros componentes, como ameaças, vulnerabilidades, e encadeamento em margarida.

Importante para testes de penetração

Se você quer estar pronto para um ataque, você deve ser inteligente, pensar como eles, agir como eles. Os hackers são habilidosos, tendo informações detalhadas de hardware, software, rede e outras informações relacionadas. A necessidade e a importância dos testes de penetração, no mundo moderno, onde várias ameaças avançadas, como negação de serviço, roubo de identidade, roubo de serviços, roubo de informações, são comuns, a penetração do sistema garante combater o ataque de ameaças maliciosas, antecipando métodos. Algumas outras grandes vantagens e necessidade de testes de penetração é descobrir as vulnerabilidades em sistemas e implantações de segurança da mesma forma que um invasor obtém acesso:

- Identificar as ameaças e vulnerabilidades aos activos das organizações;
- Fornecer uma avaliação abrangente de políticas, procedimentos, design e arquitectura;
- Definir acções de correção para protegê-los antes de serem usados por um hacker para violar a segurança;
- Identificar o que um invasor pode acessar para roubar;
- Identificar quais informações podem ser roubo e seu uso;
- Testar e validar a proteção de segurança e identificar a necessidade de qualquer camada de proteção adicional;
- Modificação e actualização da segurança de implantação atual arquitectura;
- Reduzir a despesa de segurança de TI, aumentando o Retorno sobre a segurança Investimento (ROSI).

Tipos de teste de penetração

É importante diferenciar três tipos de teste de penetração porque um testador de penetração pode ter solicitado a execução de qualquer um deles.

O teste de **caixa preta** é um tipo de teste de penetração em que o *pentester* é um teste cego ou duplo-cego, ou seja, sem conhecimento prévio do sistema ou qualquer informação do alvo. A caixa preta é projetada para demonstrar uma situação emulada como um atacante no combate a um ataque.

Caixa cinza, é um tipo de teste de penetração em que o *pentester* tem conhecimento prévio muito limitado do sistema ou qualquer informação de alvos como endereços IP, sistema operacional ou informações de rede muito limitadas. O *Gray box* foi projetado para demonstrar uma situação emulada, pois um insider pode ter essas informações e para combater um ataque, pois o *pentester* possui informações básicas e limitadas sobre o alvo.

O teste de **caixa branca** é um tipo de teste de penetração em que o *pentester* tem conhecimento completo do sistema e informações do alvo. Esse tipo de penetração é feito por equipes internas de segurança ou equipes de auditorias de segurança para realizar auditorias

Fases do teste de penetração

1. Fase Pré-Ataque;
2. Fase de Ataque;
3. Fase Pós-Ataque.

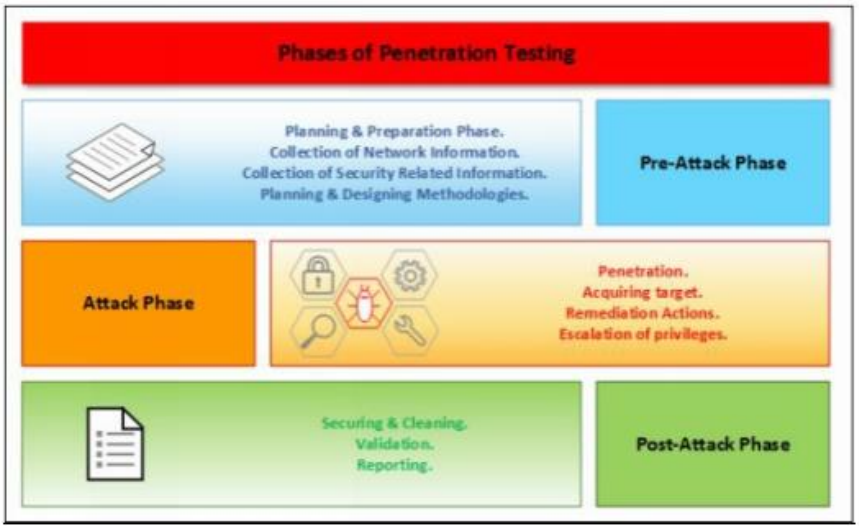

Figura 5 - Fases dos testes de penetração

11. Metodologia de teste de segurança

Existem algumas abordagens metodológicas a serem adotadas para testes de segurança ou penetração. As metodologias de teste de penetração líderes do sector são:

- Open Web Application Security Project (OWASP);
- Manual de Metodologia de Teste de Segurança de Código Aberto (OSSTMM);
- Estructura de Avaliação de Segurança de Sistemas de Informação (ISAF);
- Metodologia EC-Council Licensed Penetration Tester (LPT).

12. Componente prática

- hackertarget.com;
- exploit-db.com;
- whois.icann.org;
- whois.com;
- whois.net;
- nmap;
- Advance ip scanner;
- Técnicas de hacking google dorking;
- netcraft.com;
- Google earth;
- privateeye.com;
- anywho.com;
- Redes sociais (linkdin, facebook, instagram,twitter, etc.);
- peoplesearchnow.com;
- peoplefinders.com;
- shodan.io – pesquisa diferentes tipos de objectos na internet;
- httrack.com – cópia web sites da internet;
- surfoffline.com - cópia web sites da internet;
- weyback machine;
- website-watcher – monitora actualizações de sites na internet;
- changedetection.com – monitora actualizações de sites na internet;
- anonimox extension – permite utilizar o conceito de proxy bouncing;
- builtwith extension – permite mostrar as tecnologias utilizadas no desenvolvimento do site;
- whois.domaintools.com;
- alexa.com – monitora a audiência de sites;
- nessus;

13. Conclusão

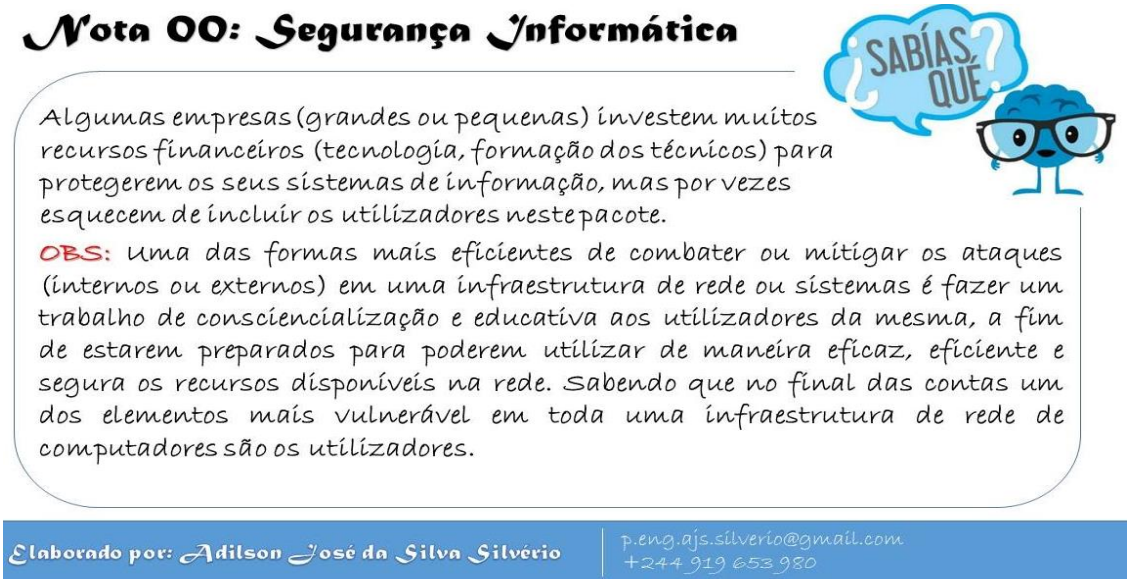

Figura 6 – Nota sobre segurança informática

14. Referências

Borges, J. J. B. V. (2010). *A Segurança e Defesa numa perspectiva do contexto regional ibérico: os novos instrumentos de articulação de políticas e estratégias*. Iº Congresso Nacional de Segurança e Defesa, Lisboa. Obtido de http://icnsd.afceaportugal.pt/conteudo/congresso/ICNSD_2C_texto_pdf_joao_vieira_borges.pdf

Sequeira, J. (2004). *Segurança Interna e Externa Face às Novas Realidades*. Trabalho de Investigação Individual no âmbito da Disciplina de Estratégia, do Curso do Estado-Maior 2002/2004.

ABNT – Associação Brasileira de Normas Técnicas. "ABNT NBR ISO/IEC 27002 – *Tecnologia da informação – Técnicas de segurança – Código de prática para a gestão de segurança da informação*. ABNT, 2005.

Campos, A. (2007). *Sistema de segurança da informação: controlando os riscos*. 2.ed. Florianópolis: Visual Books.

Omar, S. Stuppi, J. (2015). *CCNA Security 210-260 Official Cert Guide*. Indianapolis: Cisco Press.

IPSpecialist LTD. (2018). CEH v10: *EC-Council Certified Ethical Hacker Complete Training Guide with Practice Labs*. London.

Lei 7/17 (16 de Fevereiro de 2017). *Lei de proteção das redes e sistemas informáticos.*

Trabalho de pesquisa

- Google dorking;
- Metodologias de testes de penetração;
- Instalar o nmap, advanced ip scanner e o nessus (ou openvas) para fazer o *scanning* de um *target*.